Nội dung chính trong môn học

I- Tổng quan về chuyển đổi số

- Các khái niệm và vấn đề liên quan

II- Các nhóm công nghệ số trong CĐS

- Các công nghệ số điển hình trong CĐS

III- Các nhóm công nghệ nền tảng của CĐS

- Các công nghệ nền tảng CĐS: Cloud, Big Data, NGN, IoT, ML+AI, Security

IV- Triển khai chuyển đổi số

- Mô hình, kiến trúc, chiến lược chuyển đổi số
- Triển khai CĐS trong tổ chức, doanh nghiệp

Hdhai - Copyright

1

3.1. Nhóm công nghệ an ninh thông tin

3.1.1. Khái niệm liên quan

3.1.2. Các tiêu chí an toàn /an ninh

3.1.3. Khái quát các công nghệ an ninh

3.1.4. Công nghệ, Kỹ thuật bảo đảm an ninh

- 3.1.4.1) Che giấu thông tin
- 3.1.4.2) Kiểm soát truy nhập
- 3.1.4.3) Vành đai bảo vệ

3.1.5. Giám sát an ninh

3.1.6. Kiểm tra, đánh giá an ninh

Hdhai - Copyright

2

2

Khái niệm trong an toàn, an ninh thông tin

Mục đích của các công nghệ AT, ANTT:

- **Bảo đảm HT hoạt động ổn định khi xuất hiện lỗi, tránh và chống các tác động ảnh hưởng, các tấn công**

An toàn/An ninh (Security / Safety)

Safety: An toàn

- **Bảo vệ tránh/chống lỗi (do tự nhiên: môi trường/nhiễu)**
- **Bảo vệ tránh/chống lỗi (do con người tác động gián tiếp vô tình/ cố ý; lỗi cài đặt/ thiết kế/ vận hành/ bảo dưỡng)**
- **Duy trì hoạt động ổn định, an toàn**
- **Duy trì khôi phục sau sự cố**

Security: An toàn, An ninh

- **Bảo vệ tránh/chống tấn công phá hoại /cản trở /gây rối hoạt động**
- **Tránh/chống đánh cắp thông tin, rò rỉ thông tin**
- **Tránh/chống lỗ hổng bảo mật gây lộ lọt DL**
- **Duy trì hoạt động ổn định, an toàn**
- **Duy trì khôi phục sau sự cố**

Hdhai - Copyright

3

Khái niệm cơ bản về AT/AN

❑ **Thông tin (Information):**

- Dữ liệu có ngữ nghĩa thể hiện tri thức, nội dung số, tài sản số.

❑ **Hệ thống thông tin (Information System):**

- Hệ thống tích hợp các thành phần (thiết bị, phần mềm, cơ sở dữ liệu,liên kết mạng) phục vụ cho tạo lập/thu thập, xử lý, lưu trữ, chuyển tiếp (truyền tải) thông tin (tri thức, nội dung số).

❑ **An toàn/an ninh thông tin (Information Security):**

- Bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy **thông tin** và **hệ thống thông tin** một cách trái phép.

Hdhai - Copyright

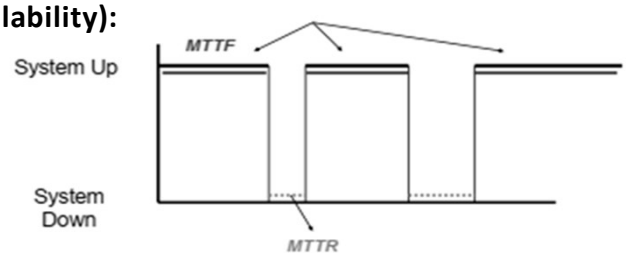
4

Các tiêu chí an toàn, an ninh thông tin

Hai tiêu chí cho hệ thống hoạt động tin cậy:

1) Tính sẵn sàng (Availability): Tính khả dụng của hệ thống (%)
2) Tính tin cậy (Reliability): Xác suất hoạt động đúng trong 1 khoảng thời gian

Tính sẵn sàng (Availability):



- Availability = Total Up-Time/Total (Up + Down-Time)
- MTTF: Mean Time To Failure
- MTTR: Mean Time To Recovery
- Availability = MTTF / (MTTF + MTTR)

Hdhai - Copyright

5

Các tiêu chí an toàn, an ninh thông tin

Tính tin cậy (Reliability):

Xác suất hoạt động đúng (XS có điều kiện)

F(t) = XS hệ thống đến thời điểm t bị lỗi

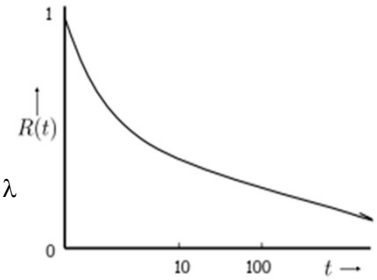
→ Hàm tin cậy ***R(t) = 1 – F(t)***

VD hệ thống có tỷ lệ lỗi theo đơn vị thời gian là λ

→ $F(t) = 1 - e^{-\lambda t}$

$R(t) = e^{-\lambda t}$

$$MTTF = \int_0^\infty e^{-\lambda t}\,dt = 1/\lambda$$



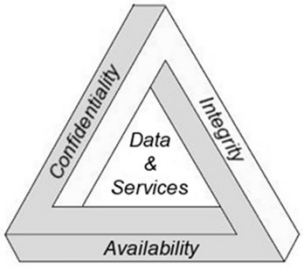
Hdhai - Copyright

6

Các thuộc tính an toàn/an ninh

❑ **Thuộc tính an toàn của thông tin và hệ thống**

- Bí mật (Confidence)
- Toàn vẹn (Integrity)
- Sẵn dùng (Availability) = khả dụng
- Xác thực (Authenticity)
- Chống chối bỏ (Non-repudation)



❖ Tính bí mật: riêng của cá nhân, tổ chức (không lọ lọt cho người khác)

- Dữ liệu riêng của cá nhân, tổ chức
- Quyền sở hữu trí tuệ của cá nhân, tổ chức
- Bí mật quốc gia.

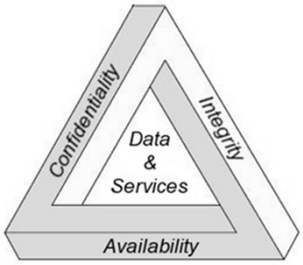
Hdhai - Copyright

7

Các thuộc tính an toàn/an ninh

❑ **Thuộc tính an toàn của thông tin và hệ thống**

- Bí mật (Confidence)
- Toàn vẹn (Integrity)
- Sẵn dùng (Availability) = khả dụng
- Xác thực (Authenticity)
- Chống chối bỏ (Non-repudation)



❖ Tính toàn vẹn: Chống sửa đổi, xóa, bổ sung trái phép (không có thẩm quyền)

- Không bị thay đổi, xóa
- Thông tin hợp lệ
- Thông tin chính xác

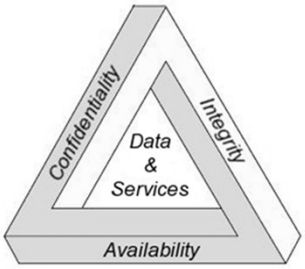
Hdhai - Copyright

8

Các thuộc tính an toàn/an ninh

❑ **Thuộc tính an toàn của thông tin và hệ thống**

- Bí mật (Confidence)
- Toàn vẹn (Integrity)
- Sẵn dùng (Availability) = khả dụng
- Xác thực (Authenticity)
- Chống chối bỏ (Non-repudation)



❖ Tính sẵn dùng: Chống cản trở, ngăn chặn trái phép

- Thời gian truy nhập (cung cấp thông tin)
- Thời gian gián đoạn do sự cố, khôi phục sự cố
- Tỷ lệ phục vụ (thời gian, lưu lượng)

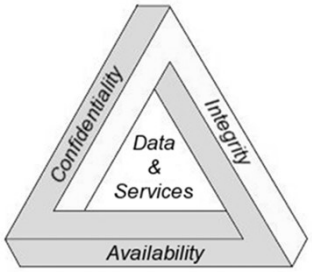
Hdhai - Copyright

9

Các thuộc tính an toàn/an ninh

❑ **Thuộc tính an toàn của thông tin và hệ thống**

- Bí mật (Confidence)
- Toàn vẹn (Integrity)
- Sẵn dùng (Availability) = khả dụng
- Xác thực (Authenticity)
- Chống chối bỏ (Non-repudation)



❖ Tính xác thực: phục vụ đúng đối tượng, đúng yêu cầu

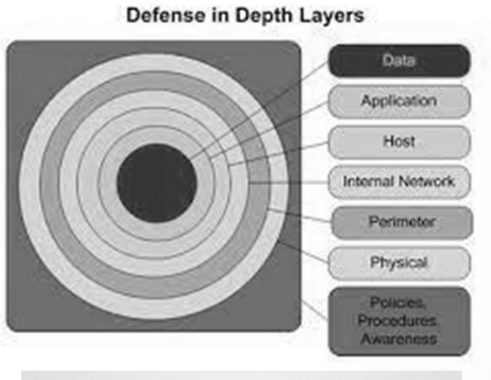
❖ Chống chối bỏ: không thể phủ nhận đã cung cấp / sử dụng

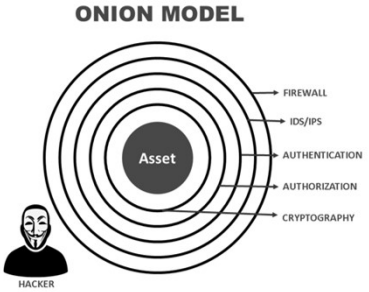
Hdhai - Copyright

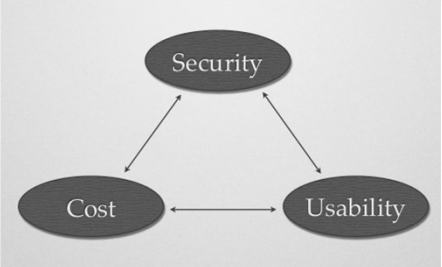
10

Nguyên tắc bảo đảm An toàn / An ninh thông tin

- Security >< Obscurity
- Bảo vệ theo chiều sâu (Defence in Depth):
- Mô hình củ hành (onion): Nhiều lớp bảo vệ, mỗi lớp có tính năng riêng
- Cân bằng giữa chi phí – bảo vệ – tính khả dụng
- Không có bảo vệ an toàn tuyệt đối







11

Khái quát nhóm công nghệ an toàn, an ninh thông tin

Physical Security, phát và chống nhiễu

Cảnh báo / Flag | Reset (State), Redirect | Watchdog | Dự phòng (redundany), Backup, Restore

Che giấu (ngụy trang), giấu tin, thủy vân số, mã hóa /nén | Thám mã

Kiểm soát truy nhập | Xác thực, chứng chỉ, chữ ký số | Block Chain

Vành đai bảo vệ, rào chắn (Gate Keeper, Filter, Proxy, Firewall, DMZ)

Phát hiện, ngăn chặn (IDS, IPS) | Đặt bẫy, đánh bắt | Phản công

Điều tra (Forensic), truy vết (Hunting)

Kiểm thử, rà quét vá lỗ hổng, kiểm định (TC 270xx, 15408,…)

Quản lý đánh giá rủi ro, kiểm toán, Policy

12

Khái quát nhóm công nghệ an toàn, an ninh thông tin

Phạm vi an toàn/an ninh thông tin

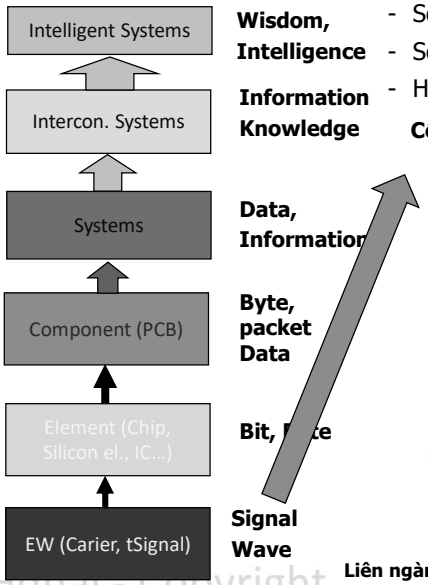
- Theo chiều dọc

- Theo chiều ngang

Hdhai - Copyright

13

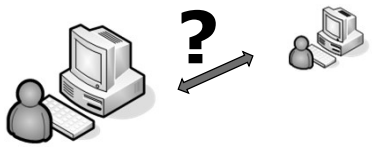
An ninh tầng vật lý



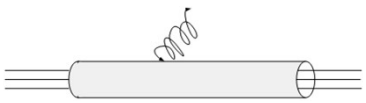
- Bức xạ điện từ, nhiệt, UV,… (Screen, Keyboard)
- Sóng phát xạ, tán xạ…
- Sóng âm: Laser, RF xuyên tường
- Hệ thống ARROW bắt sóng di động,…

Công nghệ thu trộm tín hiệu ! (hiện có vô số)

- GPS jamming, RFID, NFC, Bluetooth…



Ví dụ 1: Bắt tín hiệu từ xa ?



Ví dụ 2: → Tempest Std.

Liên ngành: Điện tử - Viễn thông - CNTT- Đa phương tiện … Tin sinh học, Phỏng sinh học (Bionics)

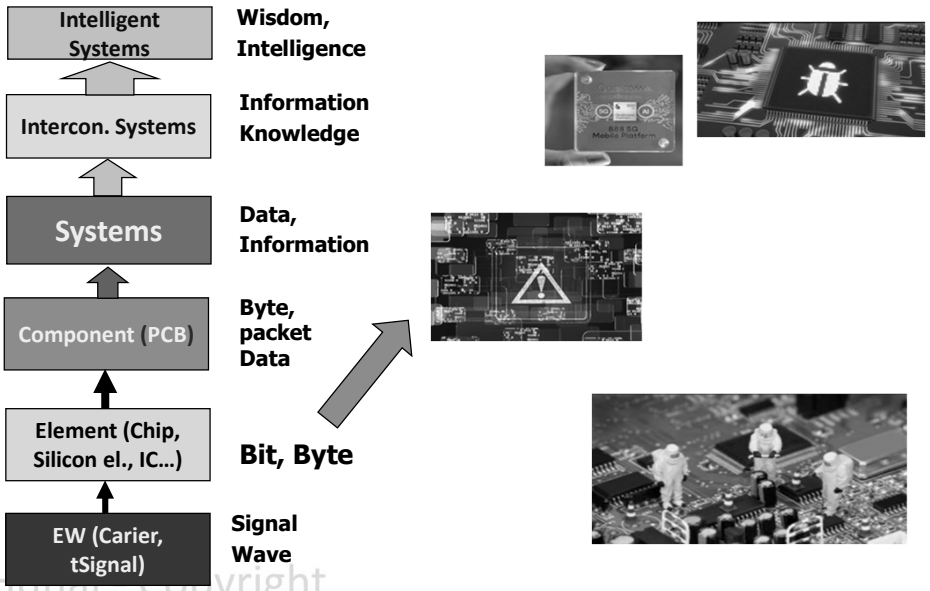
Hdhai - Copyright

14

An ninh các phần tử hệ thống

❖ An ninh các phần tử điện tử / Chip

- Chipset Malware



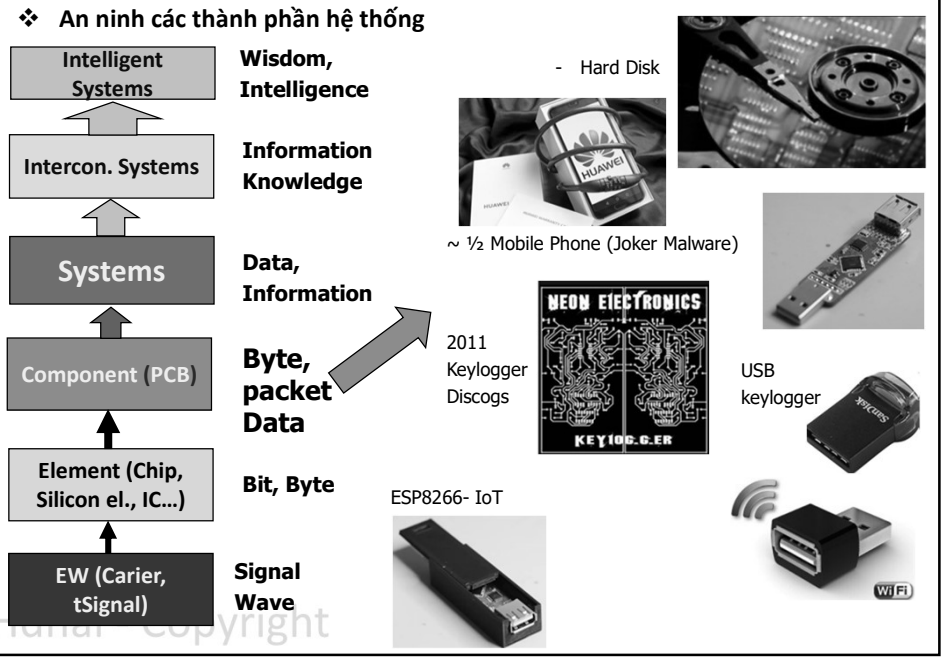
Huhar - Copyright

15

An ninh các phần tử hệ thống

❖ An ninh các thành phần hệ thống

- Hard Disk

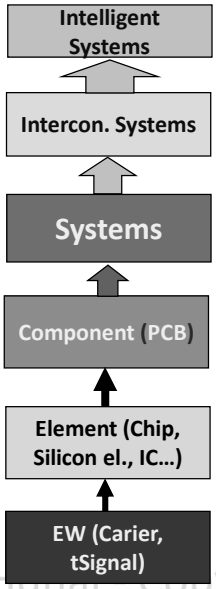


Huhar - Copyright

16

An ninh phần mềm nền tảng hệ thống (OS)

❖ An ninh hệ thống nền tảng (Windows / Linux / IoS,...)



Wisdom, Intelligence

Information Knowledge

Data, Information

Byte, packet Data

Bit, Byte

Signal Wave

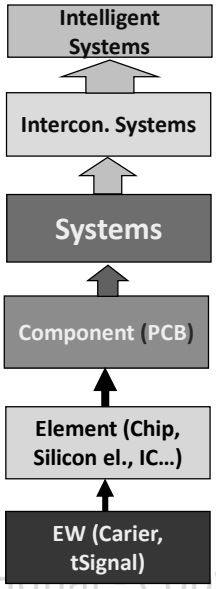
- **OS Back Door**
- Trap door của Compiler
- Trap door của PGP, VPN,...

Hunar - Copyright

17

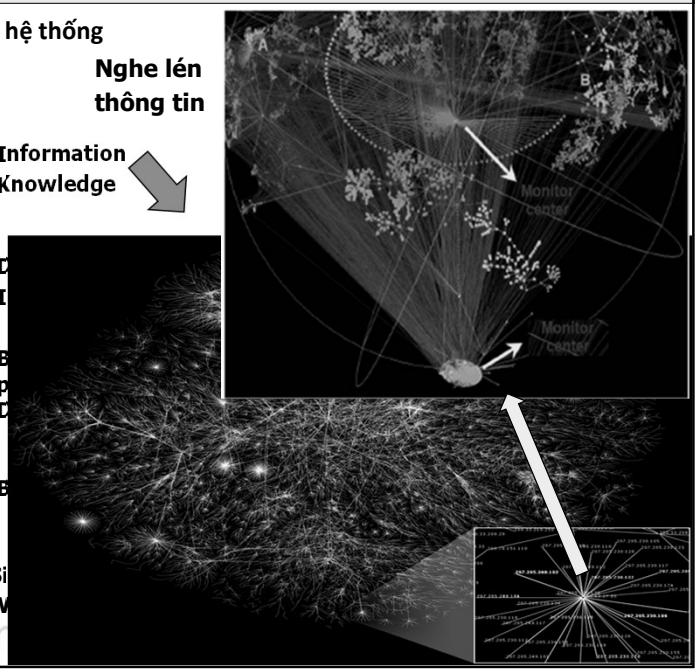
An ninh liên kết giữa các hệ thống

❖ An ninh liên mạng hệ thống



Nghe lén thông tin

Information Knowledge



Hunar - Copyr

18

3.1. Nhóm công nghệ an ninh thông tin

3.1.1. Khái niệm liên quan

3.1.2. Các tiêu chí an toàn /an ninh

3.1.3. Khái quát các công nghệ an ninh

3.1.4. Công nghệ, Kỹ thuật bảo đảm an ninh

- 3.1.4.1) Che giấu thông tin
- 3.1.4.2) Kiểm soát truy nhập
- 3.1.4.3) Vành đai bảo vệ

3.1.5. Giám sát an ninh

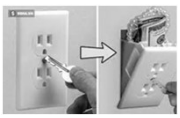
3.1.6. Kiểm tra, đánh giá an ninh

Hdhai - Copyright

Che giấu thông tin: không biến dạng thông tin

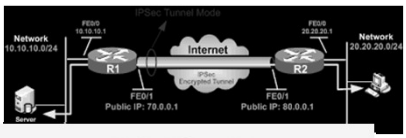
Che giấu thông tin không làm biến dạng thông tin

- Thông tin là tài sản số
- → Sự tương tự trong che giấu tài sản !

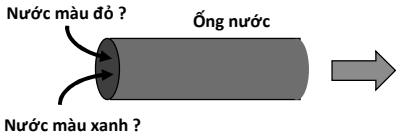


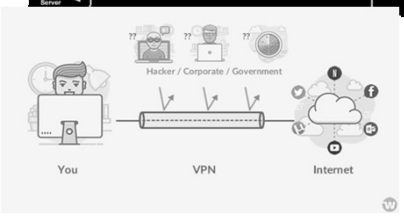
+ Che giấu bằng đường hầm (Tunneling)

Ví dụ: Cable Tunnel, IPSec Tunnel, VPN, DNS Tunnel, SSH Tunnel,...



+ VPN (Virtual Private Network)



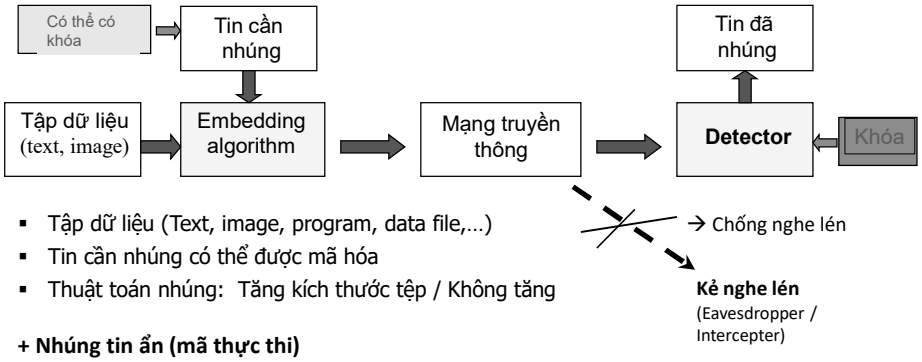


+ Giấu tin, nhúng tin
(Information Hidding, Steganography, Embedding)

Giấu tin trong văn bản, ảnh, audio, video,... (đa phương tiện)
Nhúng tin (nhúng dữ liệu, nhúng mã)

Che giấu thông tin: không biến dạng thông tin

Nhúng tin (Information Embedding)



- Tập dữ liệu (Text, image, program, data file,...)
- Tin cần nhúng có thể được mã hóa
- Thuật toán nhúng: Tăng kích thước tệp / Không tăng

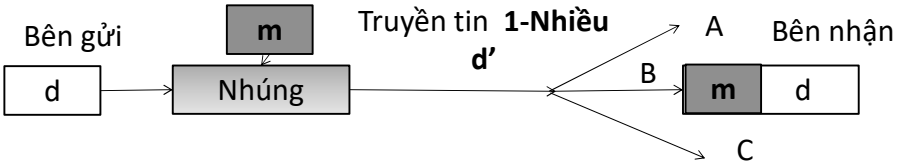
+ Nhúng tin ẩn (mã thực thi)

+ Nhúng tin không ẩn (hiển thị text, ảnh, audio, clip)

21

Che giấu thông tin: Thủy vân số

- Thủy vân số (Digital Watermarking)
- Nhúng các mẫu định danh (hoặc ảnh định danh) vào dữ liệu khác
- Dữ liệu khác: văn bản, ảnh, audio, video,...
- Mẫu định danh có thể nhìn thấy hoặc ẩn (không nhìn thấy)



- **Watermarking:** Thông tin nhúng không quan trọng (không bí mật), chỉ dùng đặc trưng cho đối tượng mang tin
- **Steganography:** Đối tượng mang tin không quan trọng, chỉ dùng để mang tin bí mật đã nhúng

Hdnai - Copyright

22

Che giấu thông tin: Mã hóa

Che giấu thông tin có làm biến dạng thông tin (mã hóa)

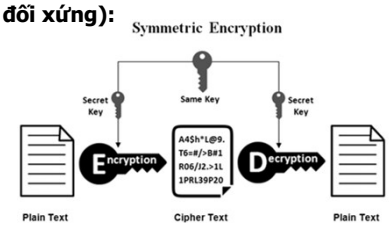
+ Mã hóa thông tin (Cryptography)

Phương pháp mã hóa một khóa (Mã bí mật, mã đối xứng):

- Mã khóa riêng, mã khóa bí mật (Private key)
- Mã hóa (bên gửi tin) với chìa khóa K

  $\mathbf{m = f (K, m) \rightarrow C_m}$
- Giải mã (bên nhận tin) với chìa khóa K

  $\mathbf{g (C_m , K) \rightarrow m}$

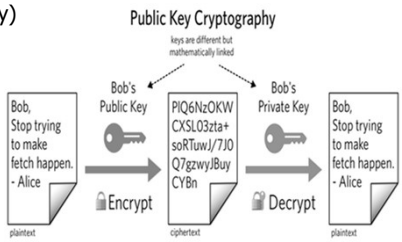


Phương pháp mã hóa 3 khóa (Mã công khai, mã bất đối xứng):

- 1 Mã khóa chung, (mã khóa công khai = Public key)
- Cả 2 bên gửi/nhận đều có khóa chung $\mathbf{K_P}$
- 2 Khóa riêng: bên gửi $\mathbf{K_A}$, bên nhận $\mathbf{K_B}$
- Mã hóa (bên gửi tin)

  $\mathbf{m = f (K_P, m) \rightarrow C_m}$
- Giải mã hóa (bên nhận tin)

  $\mathbf{g (C_m , K_B) \rightarrow m}$



23

3.1. Nhóm công nghệ an ninh thông tin

3.1.1. Khái niệm liên quan

3.1.2. Các tiêu chí an toàn /an ninh

3.1.3. Khái quát các công nghệ an ninh

3.1.4. Công nghệ, Kỹ thuật bảo đảm an ninh

- 3.1.4.1) Che giấu thông tin
- 3.1.4.2) Kiểm soát truy nhập
- 3.1.4.3) Vành đai bảo vệ

3.1.5. Giám sát an ninh

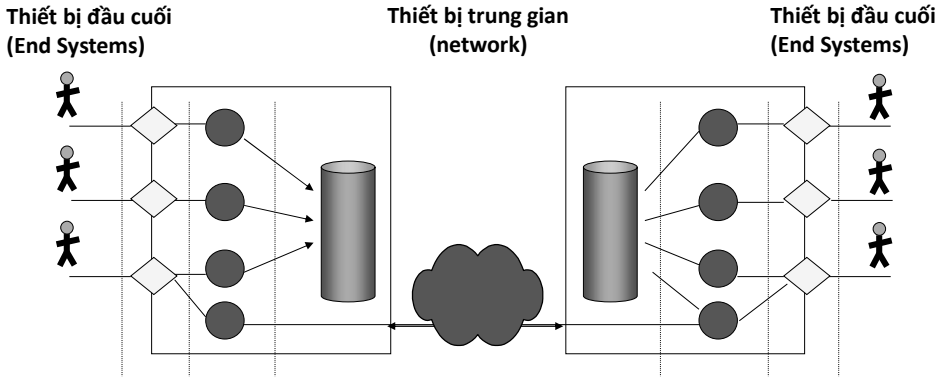
3.1.6. Kiểm tra, đánh giá an ninh

Hdhai - Copyright

24

24

Phạm vi kiểm soát truy nhập



PC, Tablet, Phone: Phần cứng, phần mềm HT (Boot, ROM), hệ điều hành, Driver, Dữ liệu HT

Truy nhập thiết bị, hệ điều hành: Tiến trình, phần mềm, ứng dụng, tệp tin

Truy nhập ứng dụng, máy chủ: Kiểm soát đăng nhập qua giao diện

Truy nhập dữ liệu: Kiểm soát truy nhập cơ sở dữ liệu

Truy nhập mạng: Kiểm soát truy nhập mạng, kết nối an toàn, bảo mật thông tin truyền

Hdhai - Copyright

25

3.1. Nhóm công nghệ an ninh thông tin

3.1.1. Khái niệm liên quan

3.1.2. Các tiêu chí an toàn /an ninh

3.1.3. Khái quát các công nghệ an ninh

3.1.4. Công nghệ, Kỹ thuật bảo đảm an ninh

- 3.1.4.1) Che giấu thông tin
- 3.1.4.2) Kiểm soát truy nhập
- 3.1.4.3) Vành đai bảo vệ

3.1.5. Giám sát an ninh

3.1.6. Kiểm tra, đánh giá an ninh

Hdhai - Copyright

26

26

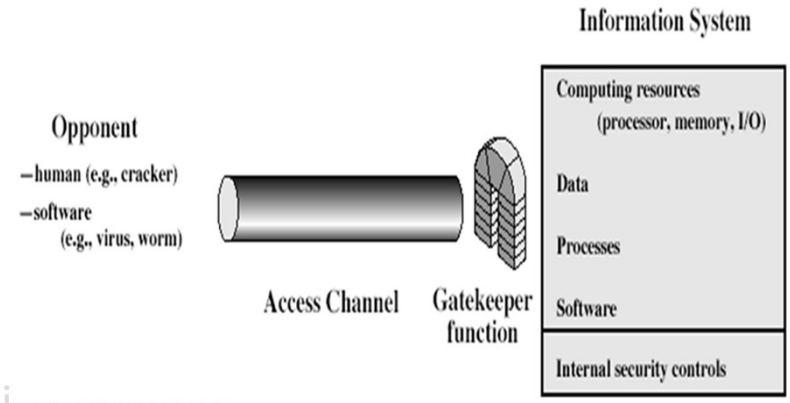
Vành đai bảo vệ: Gate keeper

Thiết bị bảo vệ (Phát hiện, ngăn chặn,…)

Gatekeeper

+ Là thiết bị (hardware) hoặc phần mềm kiểm soát truy nhập vào tài nguyên máy tính, dữ liệu, tiến trình hệ thống, phần mềm ứng dụng, các tính năng an ninh máy tính

+ Chỉ cho phép Admin có quyền truy nhập



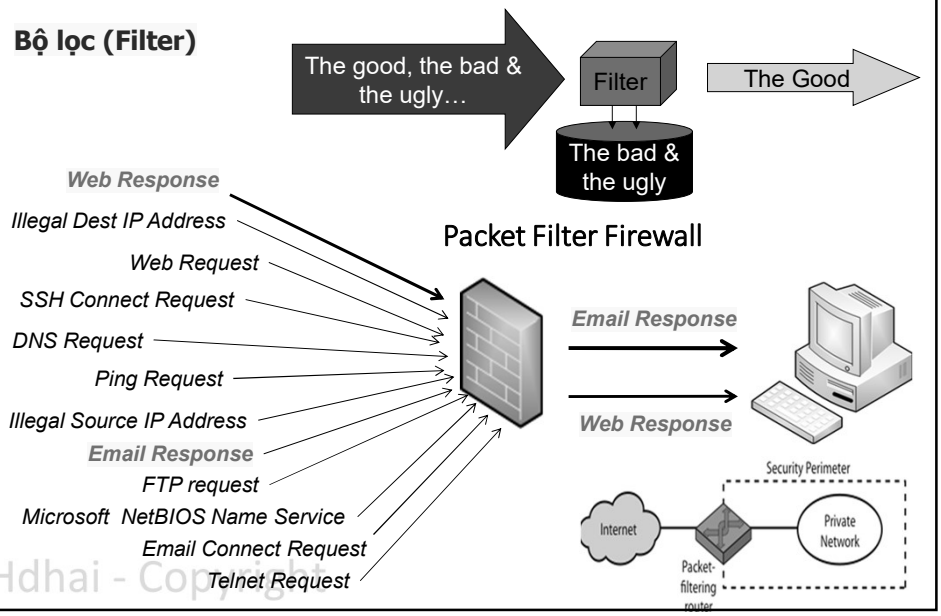
Hdhai - Copyright

27

Vành đai bảo vệ: Filter

Thiết bị bảo vệ (Phát hiện, ngăn chặn,…)

Bộ lọc (Filter)



Hdhai - Copyright

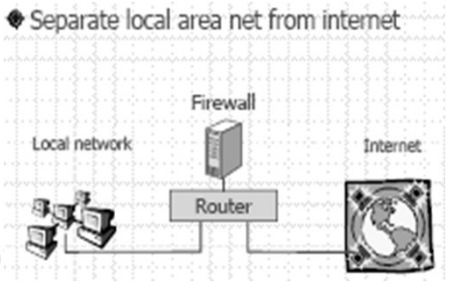
28

Vành đai bảo vệ: Firewall

Thiết bị bảo vệ (Phát hiện, ngăn chặn,...)

Thiết bị tường lửa (Firewalls)

- Kiểm soát, theo dõi thông tin vào ra. Nối hai mạng có độ tin cậy khác nhau.
- Đặt hạn chế truy nhập dịch vụ mạng = chỉ cho phép lưu lượng được phép đi qua.
- Kiểm toán và kiểm soát truy nhập = cảnh báo khi có hành vi bất thường.
- Giám sát NAT
- Ngăn chặn tấn công từ Internet (không chặn từ trong !)
- Có thể là 1 chương trình phần mềm hoặc thiết bị phần cứng lọc thông tin

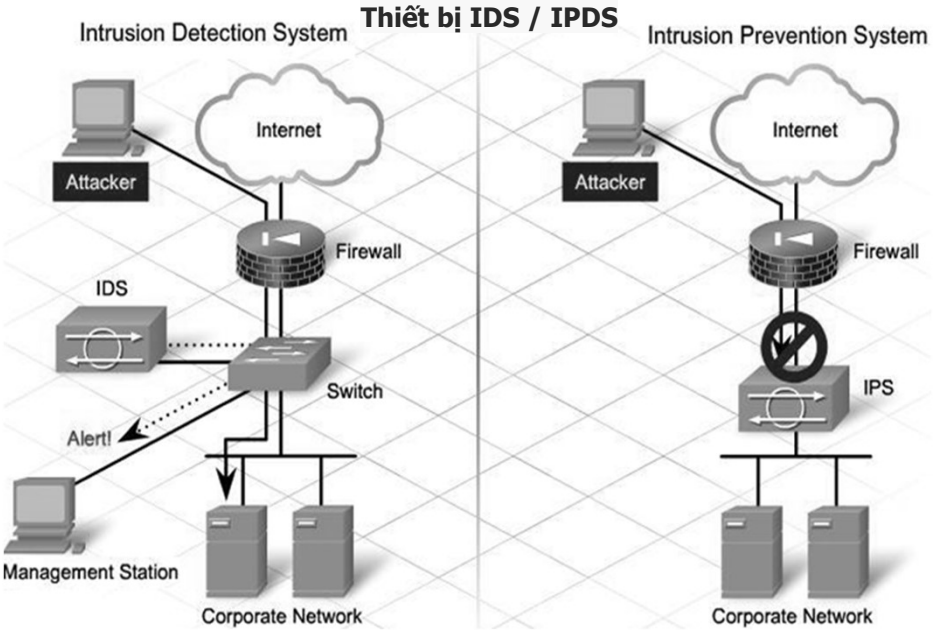


Hdhai - Cop

29

Vành đai bảo vệ: IDS và IPS

Thiết bị IDS / IPDS



30

Vành đai bảo vệ: IDS và IPS

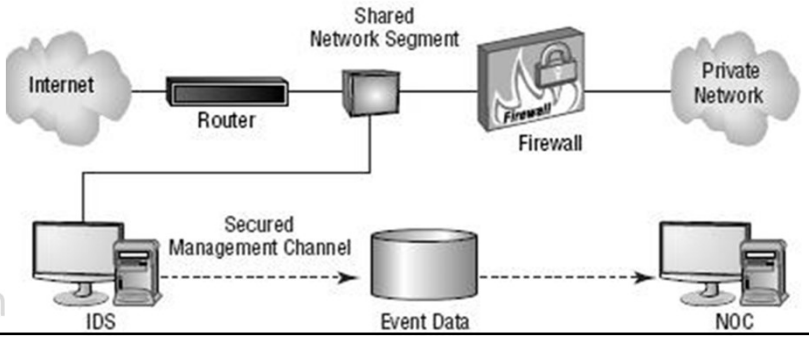
N-IDS / H-IPS

❑ Phân loại thiết bị IDS/IPDS

- Network-based IDS/IDPS (NIDPS)
- Host-based IDS/IDPS (HIDPS)
- Application-based IDS/IDPS (AIDPS).

❑ Network-based IDPS

+ Là các hệ thống NIDPS phổ biến trong thực tế. Ví dụ: ISS RealSecure, Cisco IDS…
+ NIDS phát hiện tấn công qua bắt, phân tích các gói tin qua mạng, giám sát lưu lượng mạng
+ Thường nghe thụ động (passive), không ảnh hưởng tới hoạt động bình thường của mạng
+ Bắt gói tin = Sensor (Agent) (Thiết bị hoặc phần mềm cài trên các host)



Hdh

31

Vành đai bảo vệ: IDS và IPS

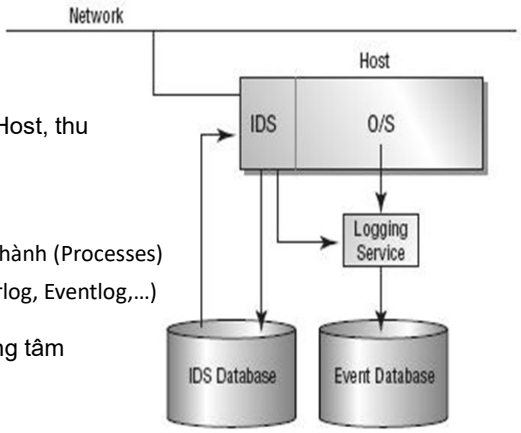
N-IDS / H-IPS

❑ Host-based IDS/IDPS

+ Là phần mềm (Agent) cài trên Host, thu thông tin từ Host

+ Sử dụng 2 nguồn tin:
- Tracing hoạt động của hệ điều hành (Processes)
- Các log hệ thống (Syslog, Errorlog, Eventlog,…)

+ Các Agent thu tin và gửi về trung tâm giám sát

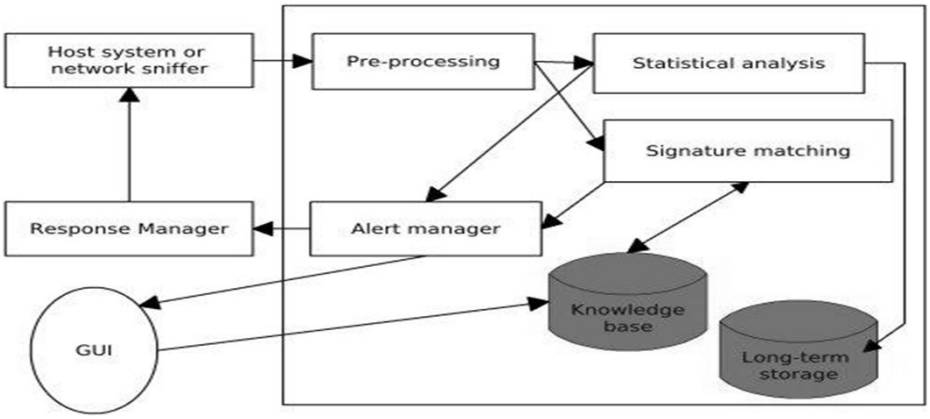


Hdhai - Copyright

32

Vành đai bảo vệ: Signature-based IDS

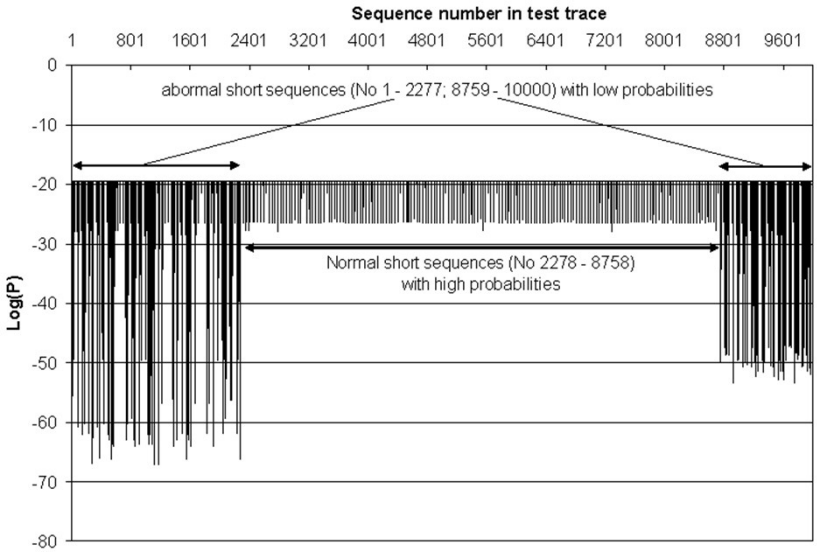
- Xây dựng cơ sở dữ liệu các dấu hiệu của các loại tấn công đã biết
- Giám sát hành vi hệ thống, cảnh báo nếu phát hiện chữ ký của tấn công
- Ưu điểm: có khả năng phát hiện các tấn công đã biết một cách hiệu quả
- Nhược điểm: không có khả năng phát hiện các tấn công mới



33

Vành đai bảo vệ: Anomale-based IDS

- Xây dựng hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường.
- Giám sát hành vi hệ thống, cảnh báo nếu có khác biệt với hồ sơ của đối tượng.

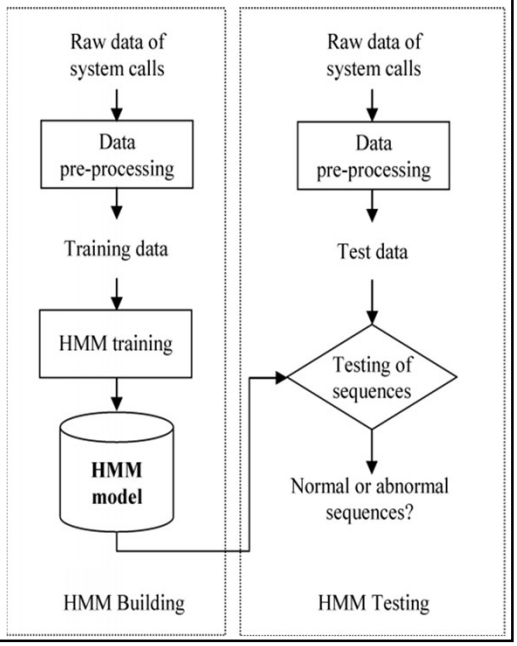


34

Vành đai bảo vệ: Anomale-based IDS

- Phương pháp xử lý, phân tích dữ liệu, mô hình hoá
- Thống kê (statistics)
- Học máy (machine learning): Naïve Bayes, SVM, HMM, máy trạng thái (state-based).
- Khai phá dữ liệu (data mining)
- Mạng nơ ron (neural networks).

Ví dụ: HMM-based Anomaly detection



35

3.1. Nhóm công nghệ an ninh thông tin

3.1.1. Khái niệm liên quan

3.1.2. Các tiêu chí an toàn /an ninh

3.1.3. Khái quát các công nghệ an ninh

3.1.4. Công nghệ, Kỹ thuật bảo đảm an ninh

- 3.1.4.1) Che giấu thông tin
- 3.1.4.2) Kiểm soát truy nhập
- 3.1.4.3) Vành đai bảo vệ

3.1.5. Giám sát an ninh

3.1.6. Kiểm tra, đánh giá an ninh

Hdhai - Copyright

36

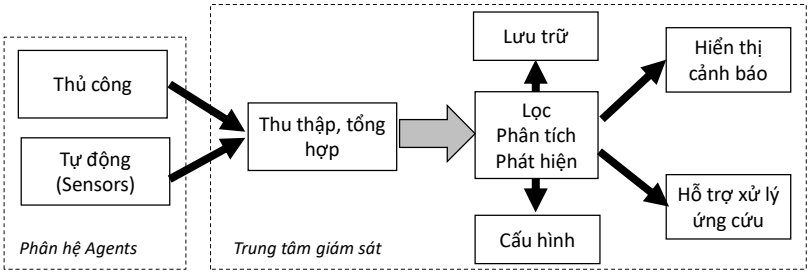
36

CÔNG NGHỆ GIÁM SÁT AN NINH THÔNG TIN

❖ **Mục đích**

+ Thu thập thông tin, theo dõi hoạt động mạng, hệ thống
+ Phân tích, phát hiện nguy cơ tấn công, sự cố
+ Cảnh báo, Hỗ trợ xử lý sự cố; Ngăn chặn, truy vết

❖ **Các thành phần hệ thống**

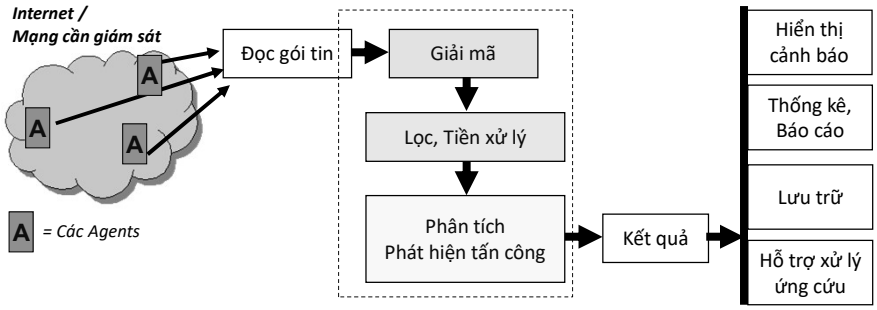


Hdhai - Copyright

37

HỆ THỐNG GIÁM SÁT AN TOÀN/AN NINH THÔNG TIN

❖ **Luồng thông tin và phương thức hoạt động của hệ thống giám sát**



+ Thu gói tin / luồng tin: pcap, wincap, beats
+ Xử lý, phân tích: Tổng hợp, lọc, tiền xử lý, giải mã
+ Phân tích, phát hiện: So sánh mẫu, tập luật → phát hiện dấu hiệu, bất thường, tương quan (Correlation, Similarity, Clustering…)
+ Cảnh báo, thống kê, báo cáo, lưu trữ. Hỗ trợ xử lý ứng cứu, ngăn chặn, truy vết.

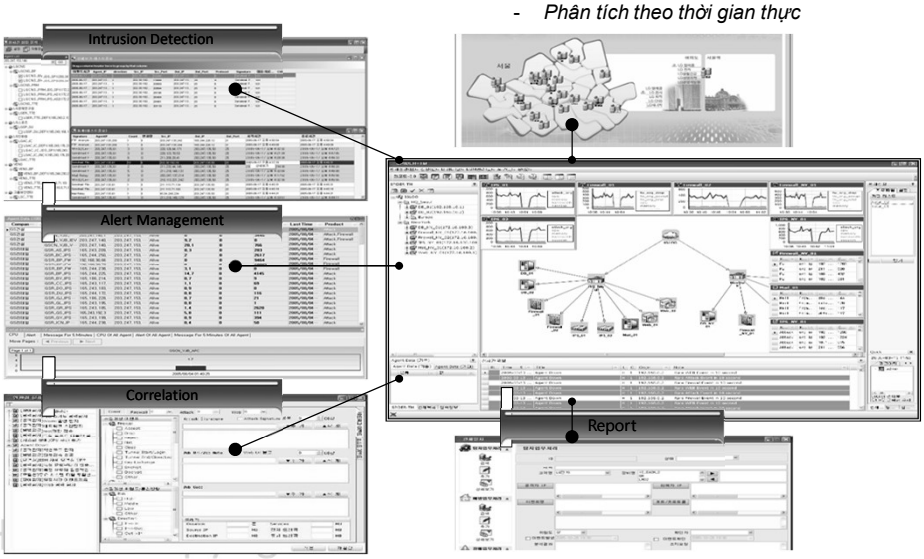
Hdhai - Copyright

38

HỆ THỐNG GIÁM SÁT AN TOÀN/AN NINH THÔNG TIN

❖ **Kết quả hiển thị phát hiện cảnh báo**

Hiển thị trực quan:
- *Phát hiện tấn công theo thời gian thực*
- *Cảnh báo theo thời gian thực*
- *Phân tích theo thời gian thực*

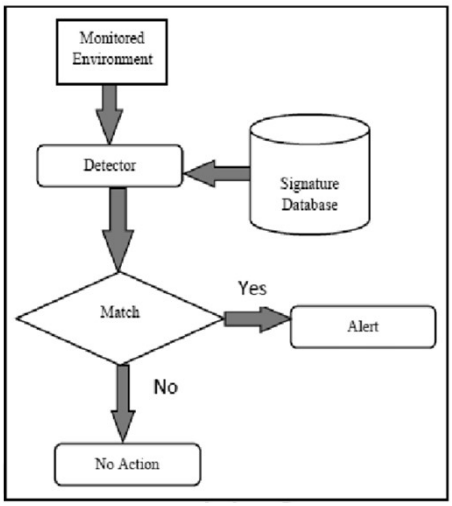


39

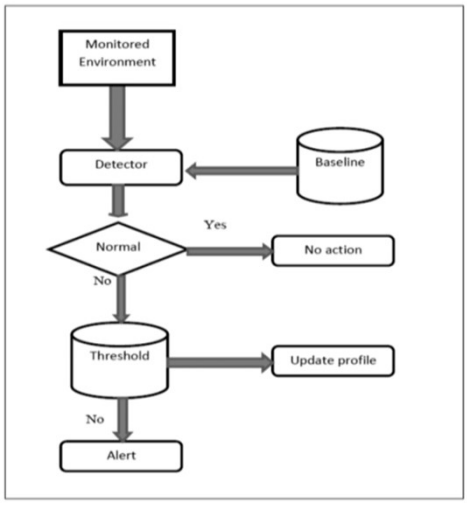
KỸ THUẬT PHÂN TÍCH, PHÁT HIỆN

❖ **Signature-based vs. Anomaly-based Detection**

Signature-based Detection

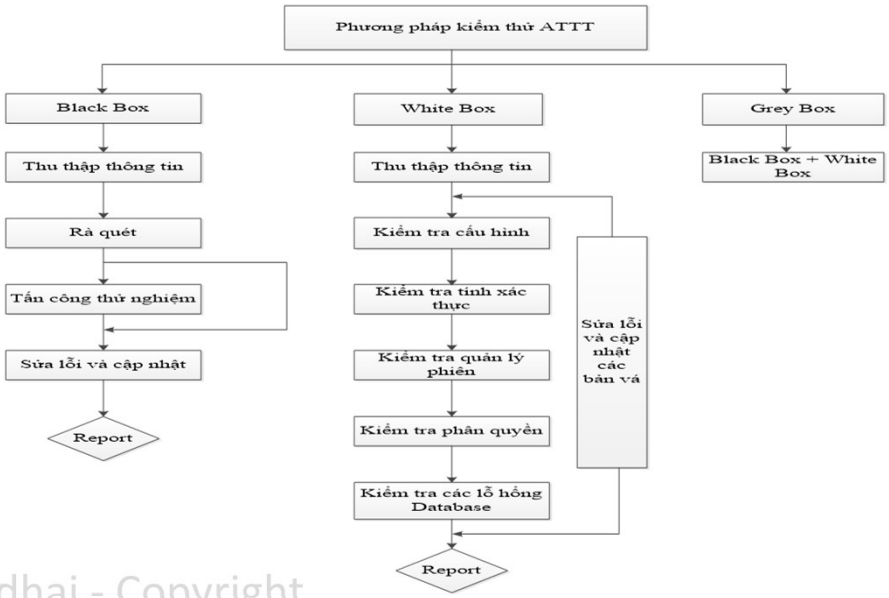


Anomaly-based Detection



40

KIỂM TRA ĐÁNH GIÁ ATTT

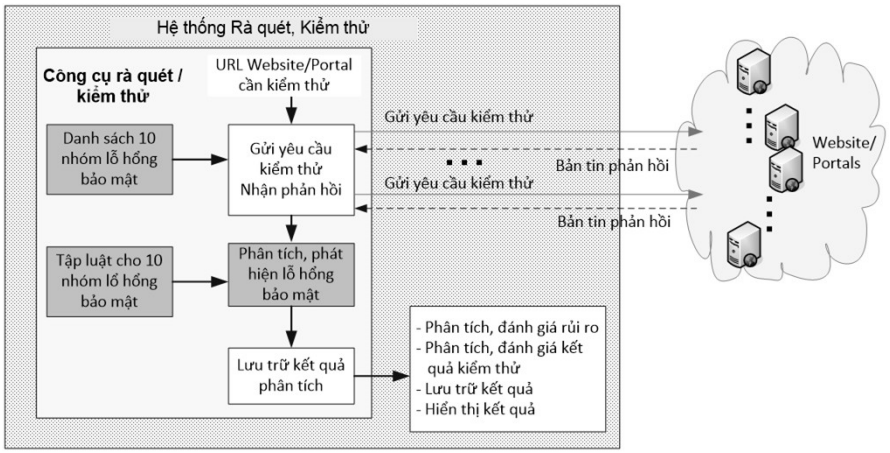


Hdhai - Copyright

41

HỆ THỐNG KIỂM TRA LỖ HỔNG BẢO MẬT

❖ **Rà quét điểm yếu, lỗ hổng bảo mật Website / Portals**



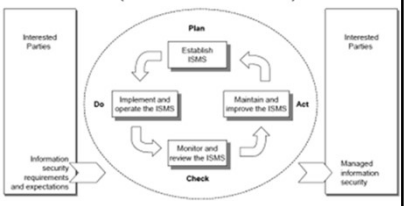
Hdhai - Copyright

42

Quản lý rủi ro, đánh giá ATAN Thông tin

- **Chuẩn ISO 2700x (PDCA)**
  - Hệ thống quản lý ATAN thông tin (ISMS)
  - 27001: Mô hình (có chứng chỉ như ISO 900x)
  - 27002: Các biện pháp bảo vệ chống nguy cơ
  - 27004/5: Quản lý, đánh giá rủi ro
  - 270xx: Các chuẩn đặc thù lĩnh vực

(Plan – Do – Check – Act)



- **Chuẩn ISO 15408 – Đánh giá ATAN thông tin**
  - Còn gọi CC (Common Criteria)
  - Đánh giá thiết bị / phần mềm
  - Mô hình TOE (target of evaluation), PP (protection profile), ST (security target)
  - EAL = Evaluation Assurance Level
  - Cấp độ đánh giá: EAL1= chức năng, EAL2= cấu trúc, EAL3= phương pháp…
- **Chuẩn OWASP**
  - Top 10 lỗi phổ biến nhất của ứng dụng Web → 10 chỉ tiêu đánh giá
  - Đánh giá cho điểm (0 – 10) từng chỉ tiêu, có thể cho trọng số

Hdhai - Copyright

43